Jenaplan Support-Reset

Kontrollierter Offlineprozess für die technische Betreuung

Schulische technische Betreuung
Version 0.3.0 · Build 302
27. Juli 2026

Zweck und feste Grenze

Das getrennte macOS-Werkzeug erzeugt keinen Benutzerzugang, kein Passwort, kein Masterkennwort und keine Entschlüsselung. Es signiert ausschließlich eine von der betroffenen Installation erzeugte technische Anfrage zu einem installations-, konto-, anfrage-, Nonce- und aktionsgebundenen `JKM-SR1`-Code. Der Code gilt standardmäßig 30 Minuten, höchstens zwei Stunden und kann nur einmal verwendet werden.

Das Werkzeug arbeitet offline. Es sucht keine Dateien, öffnet keine `kompetenzmanager.sqlite`, keine fachlichen Backups oder Dokumente, verarbeitet keine Schülerdaten und besitzt keine Cloud-, E-Mail- oder Telemetriefunktion. Anfragen und Tokens dürfen nicht in Tickets, Logs oder dauerhafte Supportprotokolle kopiert werden.

Supportpaket

Ein späteres Paket für Version `0.3.0` / Build `302` wird separat mit `scripts/build_macos_support_reset_package.sh` gebaut. Dieser Dokumentationsstand erzeugt kein Supportpaket, keine Prüfsumme und keine Übergabe. Das Paket enthält zwei Finder-Starter, eigenständige arm64-Laufzeiten, diese Anleitung, eine ausschließlich strukturelle Public-Key-Registry-Vorlage, Versionsangaben und Prüfsummen. Es enthält weder App noch DMG, synthetische Testdaten, Datenbanken, Backups, Anfragen, Tokens, Recovery-Codes, Test- oder Privatschlüssel. Es ist niemals Bestandteil eines Pilot- oder Testdatenpakets.

Die enthaltenen arm64-Executables benötigen auf dem Support-Mac keine separat installierte Python-Laufzeit. Der optionale direkte Start der versionierten Quellen ist ausschließlich ein Entwicklungsweg und benötigt Python 3.11 oder neuer sowie `cryptography` (der reproduzierbare Build verwendet 49.0.0).

Vor Verwendung `SHA256SUMS.txt` im entpackten Paket prüfen. Die `.command` muss zusammen mit dem Ordner `bin` bleiben; sie bestimmt ihren eigenen Ort und ist nicht vom aktuellen Terminalverzeichnis abhängig.

Einmalige Schlüsselbereitstellung

1	Einen ausschließlich dafür vorgesehenen, durch FileVault und ein geschütztes macOS-Konto gesicherten Support-Mac verwenden.
2	`Jenaplan-Support-Schluessel-einrichten.command` bewusst starten.
3	Ein frei gewähltes Verzeichnis außerhalb jedes Repositorys festlegen. Die Empfehlung ist `~/Documents/Jenaplan-Support-Reset/keys/`.
4	Das Werkzeug erzeugt den Ordner mit Rechten `700` und den privaten Ed25519-Schlüssel ausschließlich verschlüsselt als PKCS#8 mit Rechten `600`.
5	Eine starke, einmalige Passphrase interaktiv eingeben und bestätigen. Sie wird weder angezeigt, als Argument oder Umgebungsvariable weitergegeben noch gespeichert oder geloggt.
6	Eine eindeutige `key_id` vergeben, etwa `support-2026-a`.
7	`key_id`, Erstellungszeit, vorgesehenen Status `active` und SHA-256- Fingerprint aus der Abschlussanzeige getrennt gegen die öffentliche JSON-Beschreibung prüfen.
8	Privaten Schlüssel und Passphrase getrennt sichern. Nur öffentliche Beschreibung und Fingerprint dürfen zur Produktfreigabe weitergegeben werden.

Die Einrichtung ändert die App-Registry nicht. Es gibt keinen Klartext-Private-Key und keine Standardpassphrase.

Manuelle Produktivaktivierung

Der produktive 0.3.0-Stand führt nach ausdrücklicher Product-Owner-Bestätigung den öffentlichen Schlüssel `support-2026-b` in `src/security/infrastructure/product_support_keys.py`. Der bestätigte SHA-256-Fingerprint lautet `76e619df93483de9313d5bf592fc852c88f1ba7ac5261018801c0fcd5e96be77`. Aktivierung bleibt ein gesonderter, geprüfter App-Release:

1	Öffentliche Beschreibung und Fingerprint über getrennte Kanäle vergleichen.
2	`key_id`, Algorithmus `Ed25519`, Base64url-Public-Key, Status, `not_before`, `not_after`, optionales `revoked_at` und Fingerprint in Registry-Format 1 übertragen.
3	Niemals die private PEM-Datei oder Passphrase in Repository, Buildordner, App, DMG oder Paket kopieren.
4	Registry-, Signatur-, Bundle-, Paket- und Geheimnisscan vollständig ausführen.
5	Erst den geprüften App-Release verteilen; es gibt keine Laufzeit- oder Netzwerkfreischaltung.

Registry-Format 1 verlangt ein technisches `not_after`. Für diesen Schlüssel steht `9999-12-31T23:59:59Z` für kein bewusst terminiertes Ablaufdatum; Rotation und sofortiger Widerruf per App-Release bleiben unverändert verpflichtend.

Die App akzeptiert `active` und während einer kurzen Rotation `retiring`. `retired`, `revoked`, unbekannte, noch nicht gültige und abgelaufene Schlüssel werden abgelehnt. Für Rotation wird der neue Schlüssel vor dem Wechsel als `active` ergänzt, der bisherige höchstens für das kurze

Token-Überlappungsfenster `retiring` geführt und danach `retired`. Bei Kompromittierungsverdacht wird er sofort `revoked`; die aktualisierte Registry benötigt ein App-Update.

Reset-Code erzeugen

1	Identität und Berechtigung der anfragenden Lehrkraft organisatorisch prüfen.
2	`Jenaplan-Support-Reset.command` starten. Keine Werte in Shell-History oder Prozessargumente schreiben.
3	Anfrage als bewusst gewählte `.jkmresetrequest`-Datei oder eingefügten kanonischen Block übergeben. Das Werkzeug sucht nicht automatisch.
4	Gezeigte Anfragen-ID, gekürzte Installations-/Konto-ID und Zeitfenster prüfen und mit `JA` bestätigen, dass die Anfrage vom betroffenen Gerät stammt.
5	Verschlüsselte private PKCS#8-Datei und zugehörige öffentliche Beschreibung bewusst auswählen. Der Fingerprint und die Schlüsselpaarbindung werden geprüft.
6	Passphrase verdeckt über `getpass` eingeben. Nach drei Fehlversuchen endet der Vorgang.
7	15, 30, 60 oder höchstens 120 Minuten wählen; 30 Minuten ist Standard.
8	Ziel der `.jkmresettoken`-Datei bewusst festlegen. Vorhandene Dateien werden nicht überschrieben; die neue Datei erhält Rechte `600`.
9	Den Token nur bei begründetem Bedarf zusätzlich im Terminal anzeigen. Keine Screenshots, Zwischenablage-Historie oder Protokollierung.
10	Der Lehrkraft ausschließlich die Token-Datei beziehungsweise den Token über den vereinbarten sicheren Kanal übermitteln. Danach temporäre Übertragungen löschen, ohne Auditlogs mit Tokeninhalt anzulegen.

Die Abschlussanzeige enthält nur Zielpfad, Ablaufzeit, `key_id` und Fingerprint, niemals Passphrase oder privaten Schlüsselinhalt.

App-Seite und Fehlerfälle

Recovery-Code ist der normale erste Wiederherstellungsweg. Nur wenn Passwort und Recovery-Codes verloren sind, erzeugt die Lehrkraft unter `Passwort vergessen` beziehungsweise `Weitere Wiederherstellungsmöglichkeiten` die technische Anfrage. Sie kopiert oder speichert diese bewusst und sieht den Hinweis, dass keine Schülerdaten enthalten sind.

Die App prüft den importierten oder eingefügten Code zunächst ohne Änderung. Vor dem Reset bestätigt die Lehrkraft das Sicherheitsbackup. Erst ein vollständig erzeugtes und erneut verifiziertes `.jkmbackup` erlaubt den atomaren Übergang zu `password_reset_pending`. Altes Passwort, alte Recovery-Codes, gespeicherte Anmeldung und Touch ID werden unwirksam. Beim nächsten Start setzt die Lehrkraft selbst ein neues Passwort, erhält zehn neue Recovery-Codes und bestätigt deren Sicherung. Fachliche Daten bleiben unverändert.

Bei beschädigter, falscher oder abgelaufener Anfrage, falschem Schlüssel, Passphrasefehler, bestehender Zieldatei oder ungültiger Laufzeit sicher abbrechen und neu beginnen. Bei App-seitigem

Signatur-, Bindungs-, Wiederverwendungs- oder Backupfehler keinen Umgehungscode erzeugen und kein Backup umgehen. Ein neuer Versuch benötigt bei abgelaufener oder widerrufener Anfrage eine neue Anfrage aus der betroffenen App.

Verlust, Widerruf und Kompromittierung

1	Bei Verlust der Passphrase ist der Schlüssel nicht wiederherstellbar; einen neuen Schlüssel provisionieren und per App-Update rotieren.
2	Bei Verlust des privaten Schlüssels, Verdacht auf Kopie, unbefugten Zugriff oder Passphrase-Offenlegung den Schlüssel sofort organisatorisch sperren, in der Registry `revoked` setzen, ein App-Update bereitstellen und einen neuen Schlüssel mit neuer `key_id` provisionieren.
3	Bestehende Tokens bleiben durch kurze Laufzeit, Anfragebindung und Einmaligkeit begrenzt, dürfen aber nicht als sicher behandelt werden. Es gibt keinen unsignierten Notfallcode und kein Masterkennwort.